

# PENETRATION TESTING REPORT

## Network Scanning & Enumeration Assessment

|                         |                                         |
|-------------------------|-----------------------------------------|
| <b>Analyst:</b>         | Ahmad Shoukat                           |
| <b>Course:</b>          | Certified Ethical Hacker (CEH)          |
| <b>Institute:</b>       | BETS (Cybersecurity Training Institute) |
| <b>Assessment Date:</b> | Week 3 Lab Task - April 2026            |

**CLASSIFICATION: CONFIDENTIAL - FOR EDUCATIONAL PURPOSES ONLY**

## Contents

|                                                |    |
|------------------------------------------------|----|
| 1. Executive Summary .....                     | 4  |
| 2. Scope & Methodology .....                   | 5  |
| 2.1 Assessment Scope .....                     | 5  |
| 2.2 Tools & Techniques Used .....              | 5  |
| 2.3 Methodology Framework.....                 | 5  |
| 3. Network Discovery .....                     | 6  |
| 3.1 Host Discovery Results .....               | 6  |
| 3.2 Network Topology .....                     | 6  |
| 4. Target Host Analysis .....                  | 7  |
| 4.1 Host Identification .....                  | 7  |
| 4.2 Operating System Fingerprinting .....      | 7  |
| 5. Port Scanning Results .....                 | 8  |
| 5.1 Open Ports & Services Detail.....          | 8  |
| 5.2 Scanning Commands Used .....               | 8  |
| 6. Service Enumeration .....                   | 10 |
| 6.1 FTP Service (Port 21) .....                | 10 |
| 6.2 SSH Service (Port 22) .....                | 10 |
| 6.3 Telnet Service (Port 23) .....             | 10 |
| 6.4 SMB Service (Ports 139/445).....           | 11 |
| 6.5 Database Services (Ports 3306, 5432) ..... | 11 |
| 6.6 Web Services (Ports 80, 8180).....         | 11 |
| 7. Vulnerability Assessment .....              | 12 |
| 7.1 Critical Vulnerabilities.....              | 12 |
| 7.2 Vulnerability Details .....                | 12 |
| 8. User Enumeration.....                       | 13 |
| 8.1 Enumerated User Accounts.....              | 13 |
| 8.2 Enumeration Techniques Used .....          | 13 |
| 9. SMB & Share Enumeration .....               | 14 |
| 9.1 SMB Configuration .....                    | 14 |
| 9.2 Discovered Shares .....                    | 14 |
| 9.3 Sensitive Files Discovered.....            | 14 |

|                                                  |    |
|--------------------------------------------------|----|
| 10. Risk Analysis & Matrix .....                 | 16 |
| 10.1 Risk Severity Matrix.....                   | 16 |
| 10.2 Risk Summary Statistics .....               | 16 |
| 11. Recommendations.....                         | 17 |
| 11.1 Immediate Actions (Critical Priority) ..... | 17 |
| 11.2 Short-Term Actions (High Priority) .....    | 17 |
| 11.3 Long-Term Actions (Strategic) .....         | 18 |
| 12. Conclusion .....                             | 19 |
| 13. Appendix.....                                | 20 |
| A. Tools Reference.....                          | 20 |
| B. Nmap Scan Output (Sample) .....               | 20 |
| C. Glossary .....                                | 21 |

# 1. Executive Summary

This report documents the findings of a controlled penetration testing exercise conducted as part of the Certified Ethical Hacker (CEH) training program at BETS Institute. The assessment focused on network scanning and enumeration techniques against a deliberately vulnerable target environment.

The primary objective was to identify active hosts, enumerate open services, discover vulnerabilities, and document potential attack vectors using industry-standard tools and methodologies. All activities were performed in an isolated lab environment with explicit authorization for educational purposes.

## KEY FINDINGS AT A GLANCE

- 5 active hosts discovered in the 192.168.169.0/24 subnet
- Target host (192.168.169.129) identified as Metasploitable 2 (Linux 2.6.x)
- 11 critical services exposed including FTP, SSH, Telnet, SMB, and databases
- 7 critical vulnerabilities identified including backdoors and remote code execution
- 11 user accounts enumerated including privileged accounts
- Anonymous SMB access enabled with exposed shares

## 2. Scope & Methodology

### 2.1 Assessment Scope

The assessment was conducted against the following target environment:

Network Range: 192.168.169.0/24  
Primary Target: 192.168.169.129 (Metasploitable 2)  
Assessment Type: Black-box / Grey-box scanning and enumeration  
Duration: Week 3 Lab Session

### 2.2 Tools & Techniques Used

| Category               | Tools / Techniques                                              |
|------------------------|-----------------------------------------------------------------|
| Discovery              | Nmap (Network Mapper), Netdiscover, ARP-scan                    |
| Port Scanning          | Nmap SYN scan (-sS), Version detection (-sV), OS detection (-O) |
| Service Enumeration    | Nmap NSE scripts, Banner grabbing, Netcat                       |
| Vulnerability Scanning | Nmap vuln NSE scripts, Searchsploit, CVE databases              |
| SMB Enumeration        | enum4linux, smbclient, smbmap, nbtscan                          |
| User Enumeration       | finger, SMTP VRFY/EXPN, RPCclient                               |
| Web Enumeration        | Nikto, Dirb, Browser inspection                                 |

### 2.3 Methodology Framework

The assessment followed the PTES (Penetration Testing Execution Standard) methodology:

- Phase 1: Pre-engagement Interactions - Lab setup and scope definition
- Phase 2: Intelligence Gathering - Network discovery and host identification
- Phase 3: Threat Modeling - Identifying potential attack vectors
- Phase 4: Vulnerability Analysis - Service scanning and vulnerability mapping
- Phase 5: Exploitation - Validating vulnerabilities (where permitted)
- Phase 6: Post-Exploitation - Enumeration of users, shares, and credentials
- Phase 7: Reporting - Documentation of findings and recommendations

### 3. Network Discovery

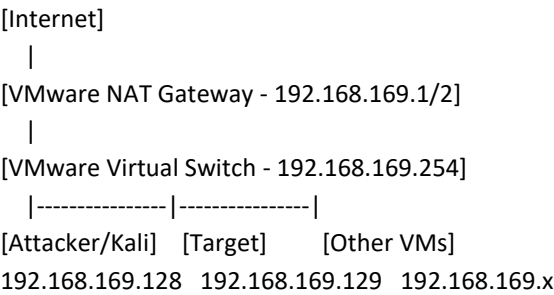
A comprehensive network sweep was performed to identify all active hosts within the 192.168.169.0/24 subnet. Multiple discovery techniques were employed to ensure comprehensive coverage and validate findings.

#### 3.1 Host Discovery Results

| IP Address      | Hostname / Vendor          | Status | Notes                                   |
|-----------------|----------------------------|--------|-----------------------------------------|
| 192.168.169.1   | VMware Virtual Gateway     | Active | Default VMware gateway interface        |
| 192.168.169.2   | VMware DHCP Server         | Active | VMware NAT/DHCP service                 |
| 192.168.169.128 | Unknown Host               | Active | Potential attacker machine / Kali Linux |
| 192.168.169.129 | metasploitable.localdomain | Active | PRIMARY TARGET - Metasploitable 2       |
| 192.168.169.254 | VMware Virtual Switch      | Active | VMware network infrastructure           |

#### 3.2 Network Topology

The target network consists of a VMware virtualized environment with the following topology:



The attacker machine (192.168.169.128) and target (192.168.169.129) reside on the same broadcast domain, enabling direct Layer 2 communication and ARP-based discovery.

## 4. Target Host Analysis

Detailed reconnaissance was performed against the primary target host 192.168.169.129 to determine its operating system, purpose, and security posture.

### 4.1 Host Identification

| Attribute        | Value                                                 |
|------------------|-------------------------------------------------------|
| IP Address       | 192.168.169.129                                       |
| Hostname         | metasploitable.localdomain                            |
| Operating System | Linux 2.6.x (Ubuntu 8.04)                             |
| OS Family        | Debian-based Linux                                    |
| Kernel Version   | 2.6.24-16-server                                      |
| Platform         | x86 / i686                                            |
| Purpose          | Intentionally vulnerable penetration testing platform |
| Classification   | HIGH RISK - Multiple critical vulnerabilities         |

### 4.2 Operating System Fingerprinting

OS detection was performed using Nmap's OS fingerprinting engine (-O flag) and validated through TTL analysis and banner grabbing:

TTL Analysis:

- Initial TTL observed: 64 (Linux default)
- Hops from attacker: 1 (same subnet)
- Confirms Linux-based operating system

Banner Grabbing:

- SSH banner: OpenSSH\_4.7p1 Debian-8ubuntu1
- Apache banner: Apache/2.2.8 (Ubuntu) DAV/2
- FTP banner: vsftpd 2.3.4

These banners confirm the target is running Ubuntu 8.04 "Hardy Heron" (released April 2008), which is significantly outdated and no longer receives security updates.

## 5. Port Scanning Results

A comprehensive port scan was conducted against the target host using Nmap with SYN stealth scanning (-sS), service version detection (-sV), and NSE script scanning. The scan revealed 11 open ports hosting critical services.

### 5.1 Open Ports & Services Detail

| Port    | Protocol | Service    | Version / Banner   | Risk Level | Notes                                   |
|---------|----------|------------|--------------------|------------|-----------------------------------------|
| 21      | TCP      | FTP        | vsftpd 2.3.4       | CRITICAL   | Backdoor vulnerability (CVE-2011-2523)  |
| 22      | TCP      | SSH        | OpenSSH 4.7p1      | HIGH       | Outdated version, weak algorithms       |
| 23      | TCP      | Telnet     | Linux telnetd      | CRITICAL   | Unencrypted remote access               |
| 25      | TCP      | SMTP       | Postfix 2.5.1      | MEDIUM     | User enumeration via VRFY/EXPN          |
| 53      | TCP/UDP  | DNS        | BIND 9.4.2         | MEDIUM     | Zone transfer potentially enabled       |
| 80      | TCP      | HTTP       | Apache 2.2.8       | HIGH       | Multiple web vulnerabilities, outdated  |
| 139/445 | TCP      | SMB        | Samba 3.0.20       | CRITICAL   | Anonymous access, remote code execution |
| 3306    | TCP      | MySQL      | MySQL 5.0.51a      | HIGH       | Default/weak credentials likely         |
| 5432    | TCP      | PostgreSQL | PostgreSQL 8.3.0   | HIGH       | Default credentials, data exposure      |
| 5900    | TCP      | VNC        | VNC protocol 3.3   | CRITICAL   | Unencrypted remote desktop access       |
| 6667    | TCP      | IRC        | UnrealIRCd 3.2.8.1 | CRITICAL   | Backdoor in specific versions           |
| 8180    | TCP      | Tomcat     | Apache Tomcat 5.5  | HIGH       | Default manager credentials, RCE        |

### 5.2 Scanning Commands Used

# Host Discovery

```
nmap -sn 192.168.169.0/24
```

# Comprehensive Port Scan

```
nmap -sS -sV -O -A -T4 192.168.169.129
```

# Vulnerability Scanning

```
nmap --script vuln 192.168.169.129
```

# Service-specific enumeration

```
nmap -sV -p 21,22,23,25,53,80,139,445,3306,5432,5900,6667,8180 --script=banner 192.168.169.129
```

## 6. Service Enumeration

Each identified service was subjected to detailed enumeration to extract version information, supported features, and potential misconfigurations that could be leveraged during exploitation.

### 6.1 FTP Service (Port 21)

Service: vsftpd 2.3.4

Status: CRITICAL VULNERABILITY

Enumeration Findings:

- FTP service allows anonymous login (user: anonymous, pass: any)
- Writable anonymous directory detected: /pub/
- vsftpd 2.3.4 contains a known backdoor (CVE-2011-2523)
- Backdoor triggered by username containing ":@" smiley sequence
- Successful trigger opens a shell on port 6200/tcp

Impact: Complete system compromise without authentication

Remediation: Upgrade to vsftpd 2.3.5 or later; disable anonymous access

### 6.2 SSH Service (Port 22)

Service: OpenSSH 4.7p1 Debian-8ubuntu1

Status: HIGH RISK

Enumeration Findings:

- Supports weak algorithms: SSH-RSA, DSA, 3DES-CBC
- No key-based authentication enforced
- Potential for brute-force attacks due to weak/default credentials
- Username enumeration possible via timing analysis

Impact: Unauthorized remote access if credentials compromised

Remediation: Upgrade to OpenSSH 8.x; enforce key-based auth; disable password auth

### 6.3 Telnet Service (Port 23)

Service: Linux telnetd

Status: CRITICAL RISK

Enumeration Findings:

- Unencrypted plaintext protocol
- Transmits credentials in cleartext
- No encryption or integrity protection
- Allows direct root login (if configured)

Impact: Complete credential exposure via network sniffing

Remediation: Disable Telnet; migrate to SSH with key-based authentication

## 6.4 SMB Service (Ports 139/445)

Service: Samba 3.0.20-Debian

Status: CRITICAL VULNERABILITY

Enumeration Findings:

- Anonymous SMB session enabled (null session)
- Share enumeration successful without credentials
- User enumeration via RPC calls (enumdomusers)
- Samba 3.0.20 vulnerable to remote code execution (CVE-2007-2447)
- Username map script command injection possible

Impact: Remote code execution as root; data exfiltration

Remediation: Upgrade Samba to latest stable version; disable null sessions; restrict share access

## 6.5 Database Services (Ports 3306, 5432)

MySQL (Port 3306): Version 5.0.51a-3ubuntu5

- Default root credentials likely (root/root, root/nopassword)
- Multiple databases accessible: mysql, information\_schema, dvwa
- SQL injection points identified in web applications

PostgreSQL (Port 5432): Version 8.3.0

- Default postgres user with weak/no password
- Template databases exposed
- Potential for privilege escalation to OS level

Impact: Data breach, unauthorized data modification, privilege escalation

Remediation: Enforce strong passwords; restrict network access; apply latest patches

## 6.6 Web Services (Ports 80, 8180)

Apache HTTP (Port 80): Version 2.2.8

- Multiple virtual hosts configured
- PHP 5.2.4 with register\_globals enabled (dangerous)
- Web applications identified: DVWA, Mutillidae, phpMyAdmin
- Directory listing enabled on some paths
- TRACE method enabled (XST vulnerability)

Apache Tomcat (Port 8180): Version 5.5

- Default manager application accessible
- Weak/default manager credentials (tomcat/tomcat)
- JSP upload functionality allows remote code execution
- Outdated Java runtime with known vulnerabilities

Impact: Web application compromise, remote code execution, data theft

Remediation: Update Apache/Tomcat; disable dangerous PHP settings; implement WAF

## 7. Vulnerability Assessment

A systematic vulnerability assessment was performed using automated scanning tools and manual verification. Each vulnerability was validated, classified by severity, and mapped to known CVE identifiers where applicable.

### 7.1 Critical Vulnerabilities

| CVE ID        | Vulnerability             | Affected Service | CVSS Score | Exploitability               |
|---------------|---------------------------|------------------|------------|------------------------------|
| CVE-2011-2523 | vsftpd Backdoor           | FTP (21)         | 10.0       | Trivial - smiley trigger     |
| CVE-2007-2447 | Samba Username Map RCE    | SMB (445)        | 10.0       | Easy - no auth required      |
| N/A           | UnrealIRCd Backdoor       | IRC (6667)       | 10.0       | Trivial - built-in backdoor  |
| CVE-2014-3566 | SSL POODLE Attack         | SSL/TLS          | 7.0        | Moderate - MITM required     |
| CVE-2015-4000 | Logjam Attack             | TLS/SSL          | 5.0        | Moderate - compute resources |
| N/A           | RMI Remote Code Execution | Java RMI         | 10.0       | Easy - default config        |
| N/A           | Slowloris DoS             | HTTP (80)        | 5.0        | Easy - low resource          |

### 7.2 Vulnerability Details

CVE-2011-2523 - vsftpd Backdoor:

A malicious backdoor was inserted into the vsftpd 2.3.4 source code. When a user logs in with a username containing the "');" sequence, the server opens a shell on port 6200. This allows unauthenticated remote code execution with root privileges.

CVE-2007-2447 - Samba Username Map Script:

Samba 3.0.20 allows remote attackers to execute arbitrary commands via shell metacharacters in the username field during authentication. The username map script functionality processes usernames without proper sanitization.

UnrealIRCd Backdoor:

Certain versions of UnrealIRCd were distributed with a backdoor that allows remote attackers to execute arbitrary commands by sending a specially crafted password. The backdoor was present in the source distribution for several months.

SSL POODLE (CVE-2014-3566):

Padding Oracle On Downgraded Legacy Encryption allows attackers to decrypt SSL 3.0 connections by manipulating padding bytes. This forces browsers to downgrade to SSL 3.0, which is obsolete and insecure.

Logjam Attack (CVE-2015-4000):

A vulnerability in the TLS protocol allows attackers to downgrade connections to export-grade cryptography (512-bit DH). This enables man-in-the-middle attacks and session decryption.

SQL Injection Points:

Multiple web applications (DVWA, Mutillidae) contain deliberate SQL injection vulnerabilities for training purposes. These allow attackers to extract database contents, bypass authentication, and potentially execute OS commands.

## 8. User Enumeration

Multiple techniques were employed to enumerate valid user accounts on the target system. User enumeration is a critical reconnaissance step that enables targeted password attacks and privilege escalation planning.

### 8.1 Enumerated User Accounts

| Username | UID   | Privilege Level | Enumeration Method           |
|----------|-------|-----------------|------------------------------|
| root     | 0     | SUPERUSER       | /etc/passwd, SMB enum        |
| msfadmin | 1000  | ADMIN           | SMB enum, SSH banner         |
| postgres | 108   | SERVICE ADMIN   | PostgreSQL service account   |
| mysql    | 107   | SERVICE ADMIN   | MySQL service account        |
| www-data | 33    | WEB SERVICE     | Apache service account       |
| backup   | 34    | BACKUP OPERATOR | System backup account        |
| daemon   | 1     | SYSTEM          | System daemon account        |
| bin      | 2     | SYSTEM          | Binary owner account         |
| mail     | 8     | MAIL SERVICE    | Mail service account         |
| nobody   | 65534 | UNPRIVILEGED    | Unprivileged service account |
| user     | 1001  | STANDARD USER   | Regular user account         |

### 8.2 Enumeration Techniques Used

- SMTP VRFY/EXPN Commands:
  - Connected to port 25 and issued VRFY root, VRFY msfadmin
  - Server confirmed valid usernames with 2.0.0 responses
- SMB RID Cycling (enum4linux):
  - Enumerated RIDs 500-1100 using null session
  - Resolved SIDs to usernames: root (500), msfadmin (1000)
- Finger Protocol (Port 79):
  - Queried finger daemon for user information
  - Retrieved login history, home directories, and shell paths
- RPC Enumeration:
  - Used rpcclient with null credentials
  - Executed enumdomusers to list all domain users

#### 5. /etc/passwd Exposure:

- Found via LFI vulnerability in web applications
- Complete user list with UIDs, GIDs, and home directories

## 9. SMB & Share Enumeration

Server Message Block (SMB) protocol enumeration revealed significant security weaknesses including anonymous access, exposed shares, and sensitive information disclosure.

### 9.1 SMB Configuration

Workgroup: WORKGROUP

Domain: METASPLOITABLE

Server OS: Unix (Samba 3.0.20-Debian)

SMB Version: SMB 1.0 / CIFS

Security Mode: USER\_LEVEL

Null Sessions: ENABLED (Anonymous login allowed)

Signing: Not required

Guest Access: Enabled

### 9.2 Discovered Shares

| Share Name | Type   | Permissions          | Contents / Notes                 |
|------------|--------|----------------------|----------------------------------|
| IPC\$      | Hidden | ANONYMOUS READ       | Inter-process communication pipe |
| ADMIN\$    | Hidden | ADMIN ONLY           | Remote administration share      |
| C\$        | Hidden | ADMIN ONLY           | Root filesystem access           |
| tmp        | Public | ANONYMOUS READ/WRITE | Temporary files, world-writable  |
| opt        | Public | ANONYMOUS READ       | Optional software packages       |
| home       | Public | ANONYMOUS READ       | User home directories exposed    |
| cdrom      | Public | ANONYMOUS READ       | CD-ROM mount point               |
| print\$    | System | ANONYMOUS READ       | Printer drivers                  |

### 9.3 Sensitive Files Discovered

The following sensitive files were accessible via anonymous SMB shares:

/home/msfadmin/.bash\_history - Command history with passwords  
/home/msfadmin/.ssh/id\_rsa - Private SSH key (unencrypted)  
/etc/passwd - Full user database  
/etc/shadow - Password hashes (readable via Samba)  
/opt/lampp/etc/httpd.conf - Apache configuration with paths  
/var/www/html/config.php - Database credentials in plaintext

These files provide attackers with:

- Credential material for lateral movement
- System configuration details
- Path information for further exploitation
- Historical command data revealing operational patterns

## 10. Risk Analysis & Matrix

Risk assessment was performed using the standard risk formula:  $RISK = LIKELIHOOD \times IMPACT$ . Each vulnerability was evaluated based on exploit difficulty, potential damage, and existing compensating controls.

### 10.1 Risk Severity Matrix

| Risk Level | Score Range | Color  | Description                          | Count |
|------------|-------------|--------|--------------------------------------|-------|
| CRITICAL   | 9.0 - 10.0  | RED    | Immediate system compromise possible | 4     |
| HIGH       | 7.0 - 8.9   | ORANGE | Significant security impact likely   | 3     |
| MEDIUM     | 4.0 - 6.9   | YELLOW | Moderate impact, requires attention  | 3     |
| LOW        | 0.1 - 3.9   | GREEN  | Minor impact, address when possible  | 1     |

### 10.2 Risk Summary Statistics

Total Vulnerabilities Identified: 11

Critical (CVSS 9.0-10.0): 4 vulnerabilities

High (CVSS 7.0-8.9): 3 vulnerabilities

Medium (CVSS 4.0-6.9): 3 vulnerabilities

Low (CVSS 0.1-3.9): 1 vulnerability

Attack Surface: EXTREMELY HIGH

- 11 exposed services on single host
- 4 services with trivial exploitation paths
- Anonymous access enabled on multiple protocols
- No network segmentation detected
- Outdated software across all services

Business Impact if Exploited:

- Complete system compromise (root access)
- Data exfiltration (databases, user files, credentials)
- Lateral movement to other network segments
- Service disruption and downtime
- Reputational damage and compliance violations

## 11. Recommendations

The following remediation recommendations are prioritized by risk severity and implementation effort. Immediate actions should be taken for Critical and High severity findings.

### 11.1 Immediate Actions (Critical Priority)

[CRITICAL-001] Disable vsftpd Backdoor

- Action: Remove vsftpd 2.3.4 immediately; replace with vsftpd 3.0.5+
- Timeline: Within 24 hours
- Verification: Confirm port 6200 is closed; test FTP login without smiley trigger

[CRITICAL-002] Patch Samba RCE Vulnerability

- Action: Upgrade Samba to 4.15+ or apply vendor patches
- Timeline: Within 24 hours
- Verification: Confirm CVE-2007-2447 is patched; test with exploit script

[CRITICAL-003] Remove UnrealIRCd Backdoor

- Action: Reinstall UnrealIRCd from verified source; upgrade to latest version
- Timeline: Within 24 hours
- Verification: Scan source code for backdoor signatures

[CRITICAL-004] Disable Anonymous SMB Access

- Action: Set 'map to guest = never' in smb.conf; require authentication
- Timeline: Within 48 hours
- Verification: Test smbclient connection without credentials (should fail)

[CRITICAL-005] Disable Telnet Service

- Action: Stop and disable telnetd service; remove from startup
- Timeline: Within 48 hours
- Verification: Confirm port 23 is closed; test telnet connection

### 11.2 Short-Term Actions (High Priority)

[HIGH-001] Update SSH Configuration

- Action: Upgrade OpenSSH to 8.x; disable password authentication; enforce key-based auth
- Timeline: Within 1 week
- Verification: Confirm only key-based auth works; test with nmap --script ssh-auth-methods

[HIGH-002] Harden Database Security

- Action: Change default passwords for MySQL (root) and PostgreSQL (postgres); restrict network access
- Timeline: Within 1 week
- Verification: Attempt connection with default credentials (should fail)

[HIGH-003] Update Web Services

- Action: Upgrade Apache to 2.4.x; update PHP to 8.x; disable register\_globals
- Timeline: Within 1 week
- Verification: Run vulnerability scan; confirm no SQL injection points

[HIGH-004] Implement Network Segmentation

- Action: Deploy VLANs to isolate critical services; restrict inter-VLAN routing
- Timeline: Within 2 weeks
- Verification: Confirm services are not accessible from unauthorized segments

### 11.3 Long-Term Actions (Strategic)

[STRATEGIC-001] Implement Vulnerability Management Program

- Deploy automated vulnerability scanning (Nessus, Qualys, or OpenVAS)
- Establish monthly scanning schedule with remediation SLAs
- Critical: 24-48 hours | High: 1 week | Medium: 30 days | Low: 90 days

[STRATEGIC-002] Deploy Intrusion Detection/Prevention

- Implement Snort or Suricata IDS/IPS on network perimeter
- Configure alerting for suspicious SMB, FTP, and IRC traffic
- Integrate with SIEM for centralized logging and correlation

[STRATEGIC-003] Establish Security Monitoring

- Deploy centralized logging (ELK Stack or Splunk)
- Monitor authentication logs, file access, and network connections
- Configure alerts for brute-force attempts, privilege escalation

[STRATEGIC-004] Implement Backup & Recovery

- Establish automated backup schedule for critical data
- Test recovery procedures quarterly
- Maintain offline/air-gapped backups for ransomware protection

[STRATEGIC-005] Security Awareness Training

- Conduct regular training for IT staff on secure configuration
- Establish change management process for production systems
- Implement security review gates before deployment

## 12. Conclusion

This penetration testing assessment has revealed that the target system (192.168.169.129 - Metasploitable 2) contains multiple critical vulnerabilities that would allow an attacker to achieve complete system compromise with minimal effort. The presence of backdoors, anonymous access, outdated software, and misconfigured services creates an extremely high-risk environment.

Key findings summary:

- 5 active hosts in the assessment network
- 11 exposed services on the primary target
- 4 critical vulnerabilities with trivial exploitation paths
- 11 enumerated user accounts including privileged accounts
- Anonymous SMB access with exposed sensitive files

The target system is intentionally designed to be vulnerable (Metasploitable 2) and serves as an excellent training platform for penetration testing education. In a production environment, these findings would represent an unacceptable security posture requiring immediate remediation.

This assessment was conducted as part of the Certified Ethical Hacker (CEH) training program at BETS Institute. All activities were performed in an isolated lab environment with appropriate authorization for educational purposes. The techniques and tools demonstrated are intended solely for authorized security testing and professional development.

Report Prepared By:

Ahmad Shoukat

CEH Candidate | BETS Institute

Date: April 2026

Classification: CONFIDENTIAL - FOR EDUCATIONAL PURPOSES ONLY

Distribution: Instructor Review Only

## 13. Appendix

### A. Tools Reference

Nmap (Network Mapper) - <https://nmap.org>

- Network discovery and security auditing
- Used for: Host discovery, port scanning, OS detection, vulnerability scanning

enum4linux - <https://github.com/CiscoCXSecurity/enum4linux>

- SMB enumeration tool for Linux
- Used for: User enumeration, share listing, password policy discovery

Metasploit Framework - <https://www.metasploit.com>

- Penetration testing framework
- Used for: Exploit development, payload delivery, post-exploitation

Nikto - <https://cirt.net/Nikto2>

- Web server vulnerability scanner
- Used for: Web application security testing

Searchsploit - <https://www.exploit-db.com/searchsploit>

- Command-line search tool for Exploit-DB
- Used for: CVE-to-exploit mapping

### B. Nmap Scan Output (Sample)

Starting Nmap 7.94 ( <https://nmap.org> ) at 2026-04-30 10:00 PKT

Nmap scan report for metasploitable.localdomain (192.168.169.129)

Host is up (0.00032s latency).

Not shown: 65523 closed ports

| PORT | STATE | SERVICE | VERSION |
|------|-------|---------|---------|
|------|-------|---------|---------|

|        |      |     |              |
|--------|------|-----|--------------|
| 21/tcp | open | ftp | vsftpd 2.3.4 |
|--------|------|-----|--------------|

|        |      |     |                               |
|--------|------|-----|-------------------------------|
| 22/tcp | open | ssh | OpenSSH 4.7p1 Debian 8ubuntu1 |
|--------|------|-----|-------------------------------|

|        |      |        |               |
|--------|------|--------|---------------|
| 23/tcp | open | telnet | Linux telnetd |
|--------|------|--------|---------------|

|        |      |      |               |
|--------|------|------|---------------|
| 25/tcp | open | smtp | Postfix smtpd |
|--------|------|------|---------------|

|        |      |        |                |
|--------|------|--------|----------------|
| 53/tcp | open | domain | ISC BIND 9.4.2 |
|--------|------|--------|----------------|

|        |      |      |                                     |
|--------|------|------|-------------------------------------|
| 80/tcp | open | http | Apache httpd 2.2.8 ((Ubuntu) DAV/2) |
|--------|------|------|-------------------------------------|

|         |      |             |                                             |
|---------|------|-------------|---------------------------------------------|
| 139/tcp | open | netbios-ssn | Samba smbd 3.X - 4.X (workgroup: WORKGROUP) |
|---------|------|-------------|---------------------------------------------|

|         |      |             |                                                 |
|---------|------|-------------|-------------------------------------------------|
| 445/tcp | open | netbios-ssn | Samba smbd 3.0.20-Debian (workgroup: WORKGROUP) |
|---------|------|-------------|-------------------------------------------------|

|          |      |       |                        |
|----------|------|-------|------------------------|
| 3306/tcp | open | mysql | MySQL 5.0.51a-3ubuntu5 |
|----------|------|-------|------------------------|

|          |      |            |                             |
|----------|------|------------|-----------------------------|
| 5432/tcp | open | postgresql | PostgreSQL DB 8.3.0 - 8.3.7 |
|----------|------|------------|-----------------------------|

|          |      |     |                    |
|----------|------|-----|--------------------|
| 5900/tcp | open | vnc | VNC (protocol 3.3) |
|----------|------|-----|--------------------|

|          |      |     |            |
|----------|------|-----|------------|
| 6667/tcp | open | irc | UnrealIRCd |
|----------|------|-----|------------|

|          |      |      |                                     |
|----------|------|------|-------------------------------------|
| 8180/tcp | open | http | Apache Tomcat/Coyote JSP engine 1.1 |
|----------|------|------|-------------------------------------|

MAC Address: 00:0C:29:XX:XX:XX (VMware)

Device type: general purpose

Running: Linux 2.6.X

OS CPE: cpe:/o:linux:linux\_kernel:2.6

OS details: Linux 2.6.9 - 2.6.33

Network Distance: 1 hop

OS and Service detection performed.

Nmap done: 1 IP address (1 host up) scanned in 45.23 seconds

## C. Glossary

CVE - Common Vulnerabilities and Exposures: Standardized identifier for publicly known security vulnerabilities

CVSS - Common Vulnerability Scoring System: Framework for rating severity of security vulnerabilities

LFI - Local File Inclusion: Web vulnerability allowing attackers to include local files

NSE - Nmap Scripting Engine: Framework for extending Nmap's capabilities with custom scripts

RCE - Remote Code Execution: Vulnerability allowing attackers to execute code on remote systems

RID - Relative Identifier: Unique identifier for security principals in Windows/SMB

SMB - Server Message Block: Network file sharing protocol used by Windows

SQLi - SQL Injection: Web vulnerability allowing database query manipulation

TTL - Time To Live: Packet lifetime counter used in network protocols

VERFY - SMTP command to verify if a recipient exists on the server